

Industrial Security (Bachelor)

Solution Sheet – Section 08

Defense in Depth

Rubric note. These are reference answers, not the only acceptable ones. Award credit for any answer that (a) names a defensible architecture, (b) cites a real product or standard, and (c) acknowledges the operational trade-off. Penalise flat-VPN designs, “patch everything” answers, and any solution that hand-waves the audit trail.

Solution

Exercise 8.1 – Vendor PLC Download Workflow. Path: Siemens engineer laptop → public Internet → brokered portal in the iDMZ (Cyolo, Claroty SRA, or BeyondTrust Privileged Remote Access) with TOTP or FIDO2 MFA → Windows jump host in iDMZ running TIA Portal, with full keystroke and screen recording (BeyondTrust session manager or Cyolo recording) → industrial firewall (Tofino, Cisco ISA-3000, Fortinet Rugged) enforcing an S7Comm-only ACL with time-of-day restriction → S7-1500. Operator approval is a click in the broker by the on-shift control-room operator; the request expires after a 30–60 minute window. Audit trail: broker auth log, MFA event, operator approval click, full session video, jump-host command history, firewall flow log, PLC project checksum before/after. Failure mode – broker outage: design ships with a documented break-glass procedure (physical key to the cabinet, two-person rule, post-hoc audit within 24 h); never a permanent VPN as fallback. *Rubric: must name broker + jump host + MFA + operator approval + recording, and one named product. Half credit for omitting the audit-trail enumeration.*

Solution

Exercise 8.2 – Counter-proposal to Flat VPN. Acknowledge the legitimate need: quarterly firmware drops, vibration tuning, warranty diagnostics. Propose a brokered remote-access service (Claroty SRA, Cyolo, BeyondTrust PRA) terminating in the iDMZ, with operator-approved sessions, full recording, and per-action MFA. Map to IEC 62443-3-3 SR 1.13 (access via untrusted networks) and SR 2.4 (mobile code). The three unacceptable risks of flat VPN: (i) lateral movement – once the tunnel is up the vendor laptop is on the plant LAN with no per-host control; (ii) persistence – a compromised vendor laptop keeps the tunnel alive 24/7; (iii) audit gap – you cannot tell which engineer did what, only that “a Siemens IP wrote to the PLC”. Pilot: 30 days, one turbine, vendor keeps their existing change-window cadence, broker covers their TIA Portal and OPC traffic only. Offer to fund the vendor account in the broker so cost is not their objection. *Rubric: must offer an alternative, not just refuse. Credit for citing 62443-3-3 or NIST SP 800-46.*

Solution

Exercise 8.3 – Passive OT IDS Placement. One sensor per substation (3) at the managed switch SPAN port, mirroring the process VLAN (IEC 61850 GOOSE/MMS, DNP3, IEC 60870-5-104) but *not* the management VLAN. One sensor at the central site on a hardware TAP between the SCADA HMI and the historian – TAP rather than SPAN because the SCADA polling load risks SPAN drops on a busy switch. Total: 4 sensors, central management plane (Malcolm/Nozomi CMC/Claroty EMC) on the iDMZ. What you miss: encrypted vendor management tunnels into the IEDs, anything that traverses the substation cellular backhaul without crossing the SPAN port, and any traffic east-west between two IEDs on the same VLAN if your switch SPAN only mirrors uplinks. Compensating controls: enforce vendor tunnel termination through the broker; deploy host-based logging on the IEDs that support it; configure SPAN to include the inter-IED traffic explicitly. *Rubric: must distinguish SPAN vs TAP and name one blind spot. Credit for explicitly stating which VLAN is mirrored.*

Solution

Exercise 8.4 – Three Layers, One Logo. Example: perimeter firewall, internal firewall, and host firewall all from the same vendor, all managed by the same management console with the same admin credentials. A single credential theft or a single zero-day in the management plane defeats all three layers simultaneously. Equivalent failure modes: three layers of detection all dependent on the same Active Directory; three AV products all using the same signature feed; three backups all written from the same backup agent with the same service account. Restore independence by mixing vendors at one layer (e.g. a Fortinet plant firewall behind a Cisco perimeter), using an out-of-band identity for the most critical management plane (a separate Tier-0 AD or local accounts), or running the management plane on a different OS family (Linux jump host fronting a Windows admin tier). *Rubric: must name the shared dependency, not just “same vendor”. Credit for an out-of-band identity proposal.*

Solution

Exercise 8.5 – “Just 5 Minutes With My Own Laptop”. Default answer: no. Backing: IEC 62443-3-3 SR 1.1 (identification and authentication of human users) and SR 1.2 (software process and device identification), reinforced by the plant’s BYOD-prohibition policy and INL DiD 2016 §5 (physical and network access control). Workaround when the read cannot wait: contractor copies the diagnostic file to a USB stick, kiosk (OPSWAT MetaDefender) scans and re-emits onto a sanitised stick, an authorised engineer mounts the sanitised stick on a hardened plant workstation. If the file must come from the laptop directly, terminate the laptop in a vendor DMZ VLAN (NAC quarantine class) and broker a one-way file transfer via a jump host. Pre-conditions for any “yes”: NAC profile assigns vendor-VLAN by certificate or one-time RADIUS PSK, EDR scan acceptable, time-boxed (30 min) authorisation ticket open, on-shift operator approves, session recorded. Audit-trail entries: ticket number, contractor identity, MAC observed by NAC, VLAN assigned, files transferred (with hashes), supervisor approval, ticket closure. *Rubric: must default to “no” before offering an alternative; must place the laptop somewhere other than the OT VLAN.*

Solution

Exercise 8.6 – Backup Plan for a Mixed Plant.

- **M580 PLC** – EcoStruxure Control Expert project + checksum, on change, 5 versions then quarterly snapshot, off-site immutable, annual restore-test on FAT bench.
- **Wonderware HMI** – AVEVA System Platform Galaxy backup + Veeam VM image, daily, 30 d incremental + 12 mo full, off-site immutable, semi-annual restore.
- **SQL historian** – native SQL full + diff + log plus Veeam VM, full weekly / diff daily / log 15 min, 90 d online + 12 mo archive, immutable bucket (S3 Object Lock), quarterly point-in-time restore.
- **12 managed switches** – RANCID or Oxidized running-config pull, on change + daily, 1 year retention, off-site, annual rebuild-of-spares test.

3-2-1 holds: two media (disk + immutable object store), at least one off-site, the immutable copy is the ransomware insurance. *Rubric: must give a frequency, retention, off-site, and restore-test for each asset. Credit for immutable storage; deduct for “daily full of 300 GB historian”.*

Solution

Exercise 8.7 – Compensating Controls for Windows 7 HMI. Priority order: (1) micro-segmentation – put the HMI behind a Tofino or Cisco ISA-3000 with an allow-list of only the PLC IPs and protocols it actually needs; protects against lateral movement from compromised IT. (2) Application allow-listing – McAfee Solidcore or AppLocker in enforce mode pinned to the frozen HMI binary set; protects against arbitrary code execution. (3) Virtual patching – Trend Micro TippingPoint or Snort/Suricata signatures in front of the HMI covering the unpatched CVEs; protects against known network-borne exploits. (4) Disable USB at OS layer via Group Policy plus McAfee Device Control; protects against the malicious-USB vector. (5) Enhanced monitoring – forward all Windows event logs and any HMI alarm exports to the OT-aware SIEM with tight alerts on logon, service creation, and registry persistence; protects nothing but cuts dwell time. Residual risk: a determined attacker with valid operator credentials and physical access to the console can still abuse the application allow-listed HMI itself – no compensating control replaces a working patch for the underlying OS. *Rubric: must rank in priority order with one named product per control. Credit for an honest residual-risk statement.*

Solution

Exercise 8.8 – OT Log Sources Splunk Misses. (1) Cisco Cyber Vision sensor alerts (S7Comm/Modbus session anomalies) – onboard via the Cyber Vision Splunk add-on, CIM map to **Network_Traffic** and **Alerts**. (2) IEC 60870-5-104 ASDU events from a Zeek dissector – ship Zeek logs through Cribl or the Splunk add-on for Zeek, custom CIM mapping for control-direction commands. (3) PLC RUN/STOP transitions from a Claroty CTD or Dragos Platform feed – syslog forwarder into Splunk with a Dragos technology add-on. (4) Wonderware/AVEVA Galaxy alarm-history rows – DB Connect or ODBC scheduled query, normalise to **Change** data model. (5) BeyondTrust PRA / Cyolo session metadata (session-start, target host, recording URL) – vendor Splunk app or CEF over syslog, normalise to **Authentication** and **Change**. Cross-source correlation rule: a successful jump-host session by vendor X (source 5), followed within 10 minutes by a PLC RUN→STOP transition (source 3) on a PLC that source 1 attributes to that jump host. Generic Splunk ES will not write that rule for you – the OT add-on is what makes it possible. *Rubric: must name five real OT sources and a real ingestion path. Credit for a correlation rule that crosses at least two of them.*

Solution

Exercise 8.9 – Honey-PLC Deployment Plan. Product: Thinkst Canary for a turnkey, supported deployment, with conpot as an open-source secondary on a Raspberry Pi for breadth. Exposes Modbus/TCP 502, S7Comm 102, EtherNet/IP 44818, and a fake Siemens Webserver on 80/443. Naming convention matches the real fleet: LINE3-PLC-07, LINE4-PLC-11, etc., so an attacker enumerating asset names cannot tell the decoy from the real PLC. Placement: one per process VLAN at Purdue Level 2 (3–5 total), one in the iDMZ at Level 3.5, one on the engineering workstation VLAN. Alerts: any TCP SYN to any honey-PLC port writes a high-severity event to the SIEM, posts to the SOC chat channel, and pages the on-call. Triage: because legitimate traffic to a honey-PLC is zero by design, a single hit is treated as a confirmed incident – isolate the source, capture pcap, kick off the IR playbook. *Rubric: must name a product, expose realistic OT protocols, and define how an alert reaches a human. Credit for the “zero false positive” framing.*

Solution

Exercise 8.10 – Spot the Bug: NAC Config. Three weaknesses. (i) MAC OUI is trivially spoofable – any attacker can set their laptop NIC to a Dell OUI in under a minute. (ii) “Dell Inc.” is one of the largest OUI blocks in existence; the rule effectively admits half the laptops on the planet. (iii) Level 3 supervisory is the wrong VLAN for a transient IT-vendor device – it places the laptop adjacent to engineering workstations and historians. Three fixes, increasing cost. (a) Replace MAB with EAP-TLS using a per-device certificate issued by the plant CA – supported by IEEE 802.1X-2020. (b) Add a posture check (Forescout SilentDefense or Cisco ISE) that verifies EDR present, OS patch level, and disk encryption before granting any VLAN – aligns with NIST SP 800-82 R3 §6 access-control guidance. (c) Terminate the vendor laptop in a vendor DMZ VLAN with no direct Level 3 access; required action goes through a brokered jump host – aligns with IEC 62443-3-3 SR1.1 and the zone/conduit model. *Rubric: must catch the MAC-spoofing weakness explicitly and propose at least one certificate-based or brokered alternative.*